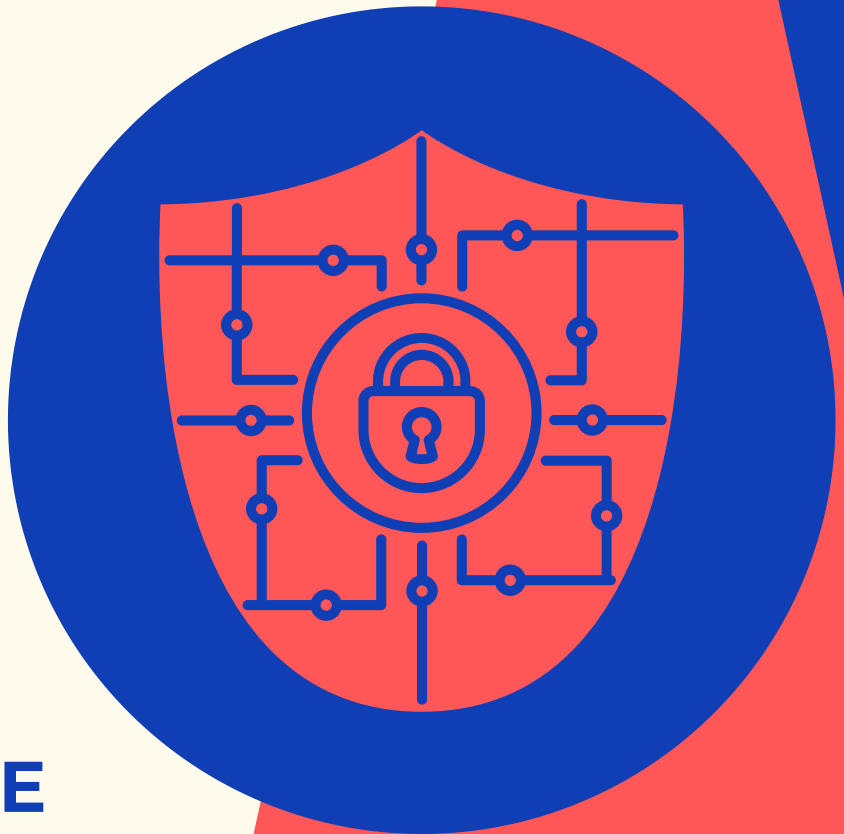
WEB APPLICATION VULNERABILITY ASSESSMENT

REPORT

FUTURE INTERNS:
TASK 01
CYBER SECURITY



PREPARED BY :

NOLUSIZO.P CELE

CONTENT :

About Assessment.....pg 01
Project Objective.....pg 02
Target website.....pg 03
Scope.....pg 03
Tools used.....pg 04
Methodology.....pg 04
Findings.....pg 05
Recommendations.....pg 09
Desclaimer.....pg 10

About Assessment

This report is for Cyber security project task 1 at future interns, where i did a vulnerability assessment on a live web application, conducted on the intentionally vulnerable testing platform demo.testfire.net.

PROJECTS OBJECTIVES:

- Identify common web vulnerabilities, Perform network-level scanning, Classify risks (Low / Medium / High) and Provide remediation rrecommendation.

TARGET WEBSITE

https://demo.testfire.nnet

SCOPE

This task follows strict ethical guidelines.
Allowed: Public-facing pages only, Passive scanning, Header checks and Configuration analysis.
Not Allowed: Login bypass, Exploitation, Brute force attacks, Denial-of-Service (DoS) and Any activity that can harm the website.

TOOLS USED

- OWASP ZAP (Zed Attack Proxy) – Web vulnerability scanning
- Nmap – Network scanning and port & analysis
- BBrowser DeveloperTools – Traffic iinspection

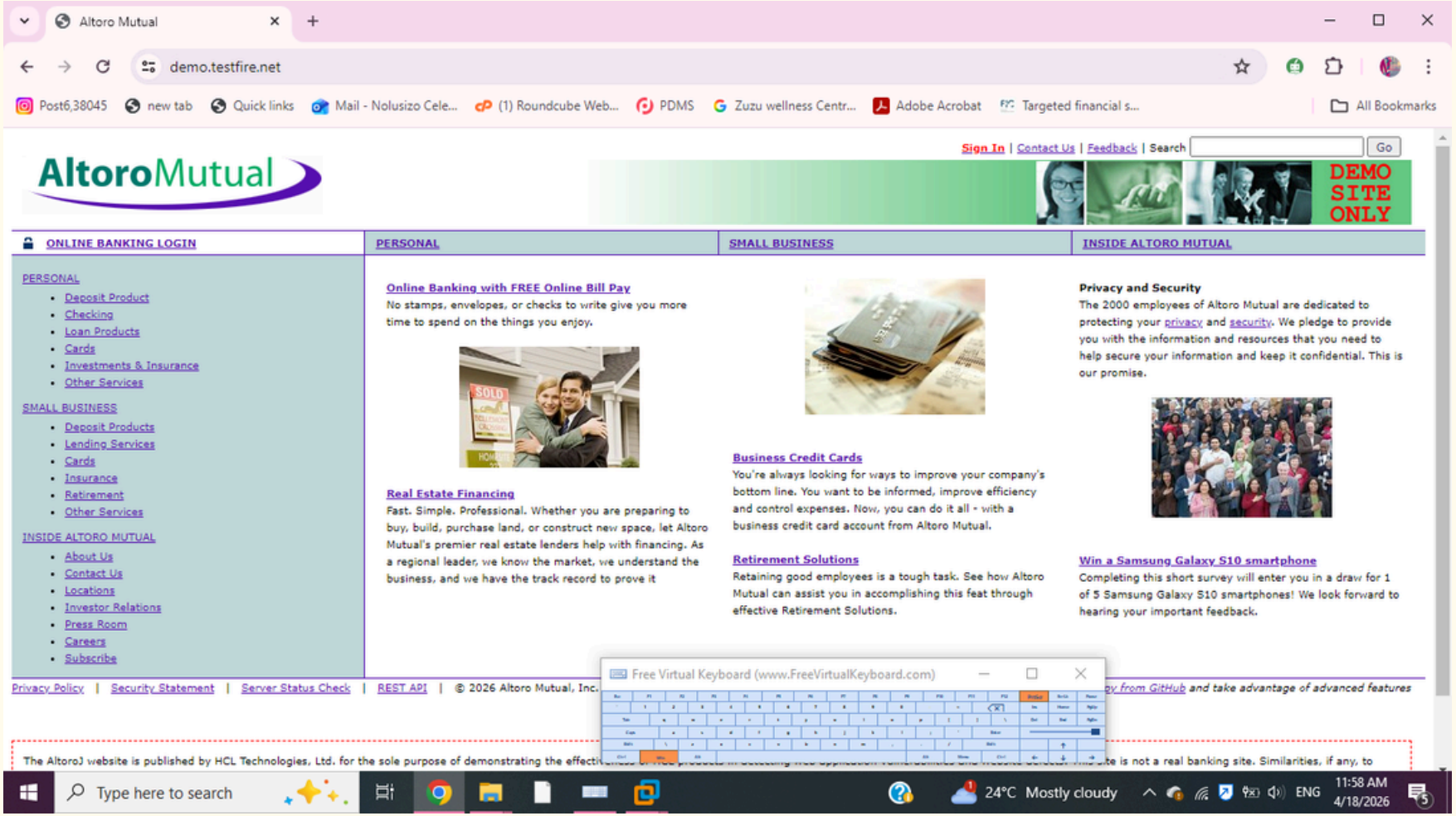
METHODOLOGY

- Conducted Nmap scan to identify filtered ports -Performed Spider Scan using OWASP ZAP to discover pages
- Executed Aotomated Scan to detect vulnerabilities
- Analyzed and classified findings based on severity

FINDINGS : SUMMARY

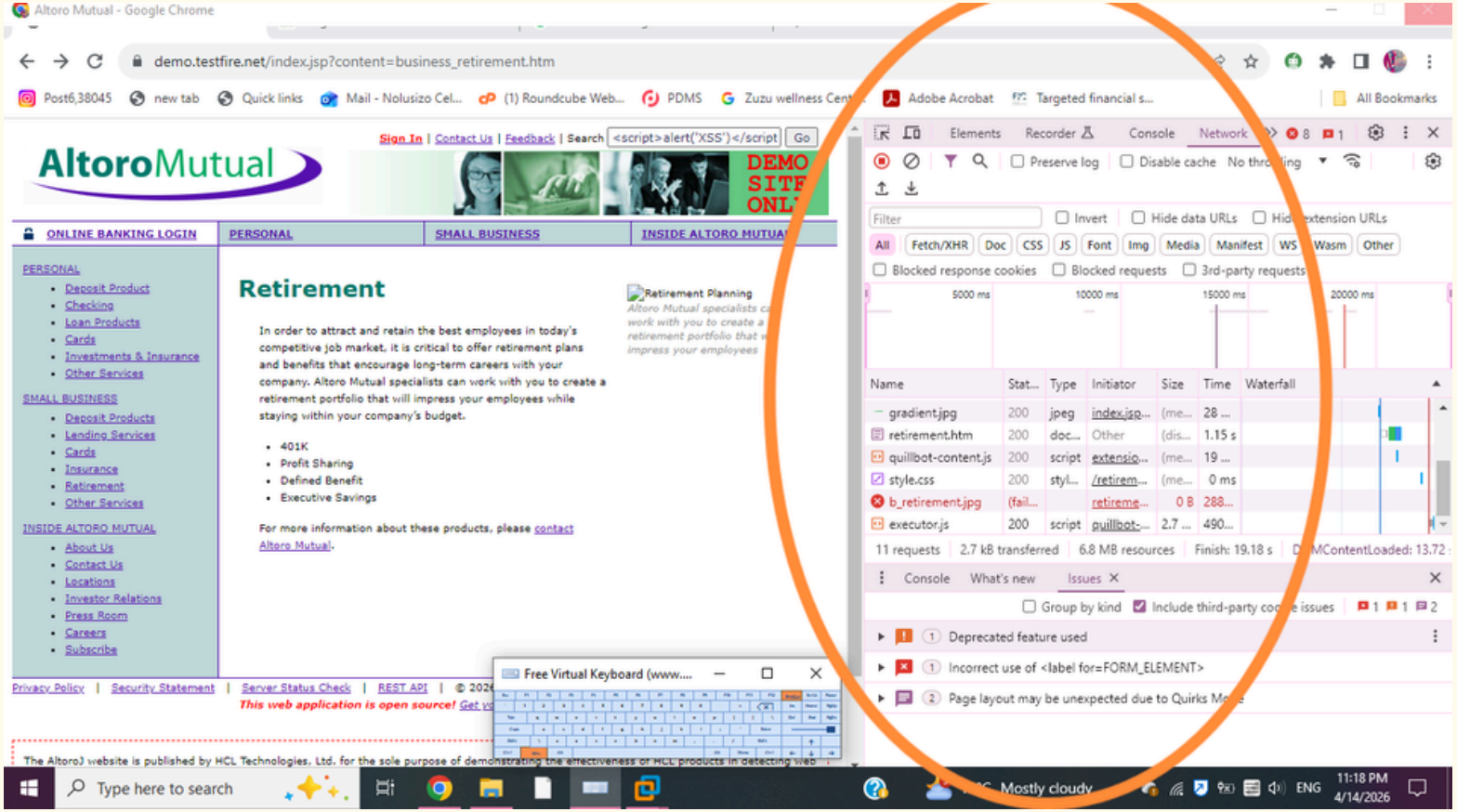
High risk vulnerabilities	Medium risk vulnerabilities	Low risk vulnerabilities
SQL injection: Risk-high Confidence - medium Critical - 9/10	Outdated JavaScript library: Risk- medium Confidence - high Critical - 5/10	Sensitive data exposed in client side: Risk - low Critical - 3/10
Cross site scripting(XSS) Risk - high Confidence - medium Critical - 9/10	Missing security headers: Risk - medium Confidence - high Critical - 5/10	insecure cookies: Risk - low Critical - 3/10
		Sever version disclosure: Risk - low Critical - 2/10

FINDINGS : EVIDENCE



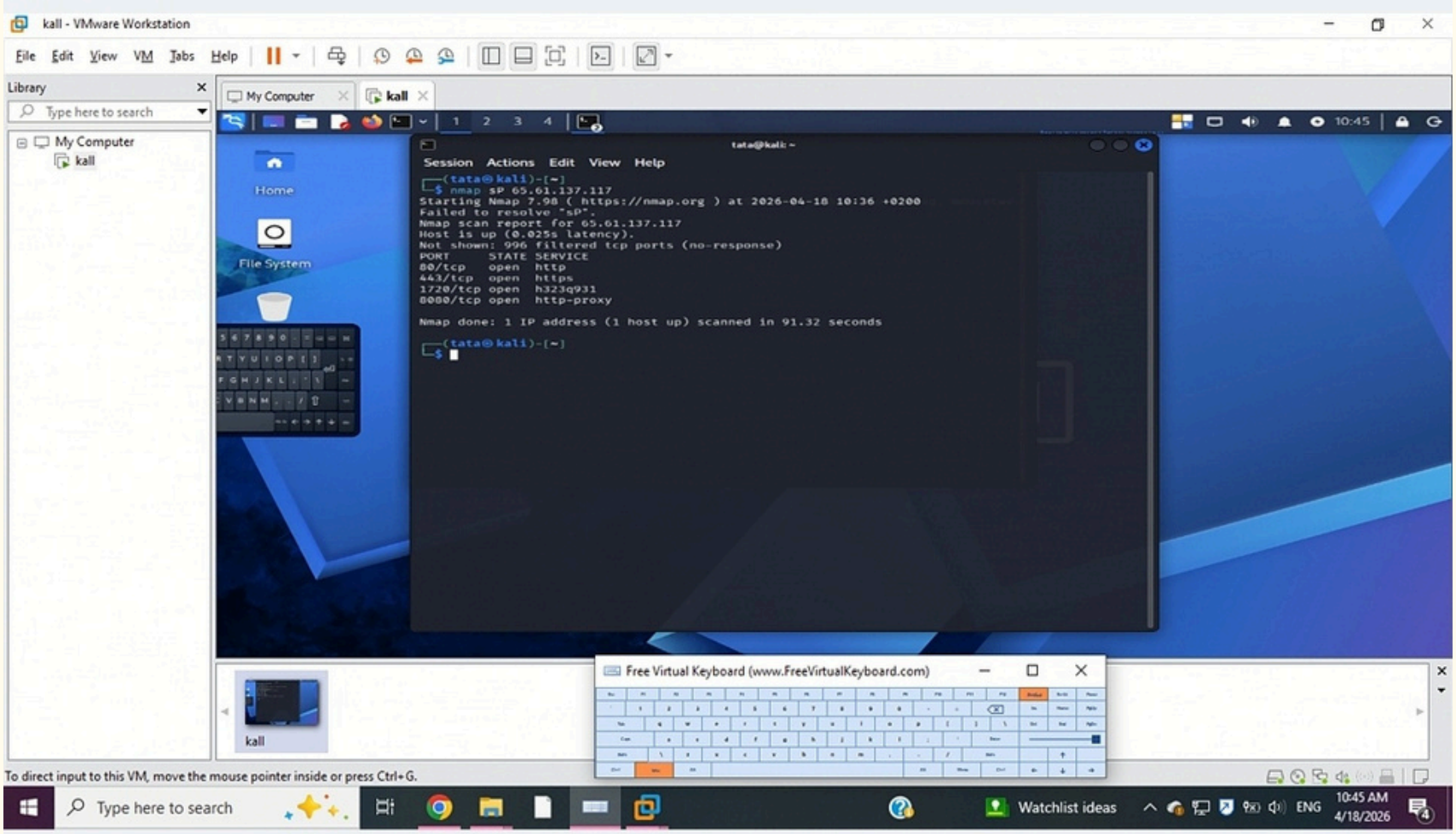
The vulnerable web application used to conduct the assessment: demotestfire.net

FINDINGS : EVIDENCE



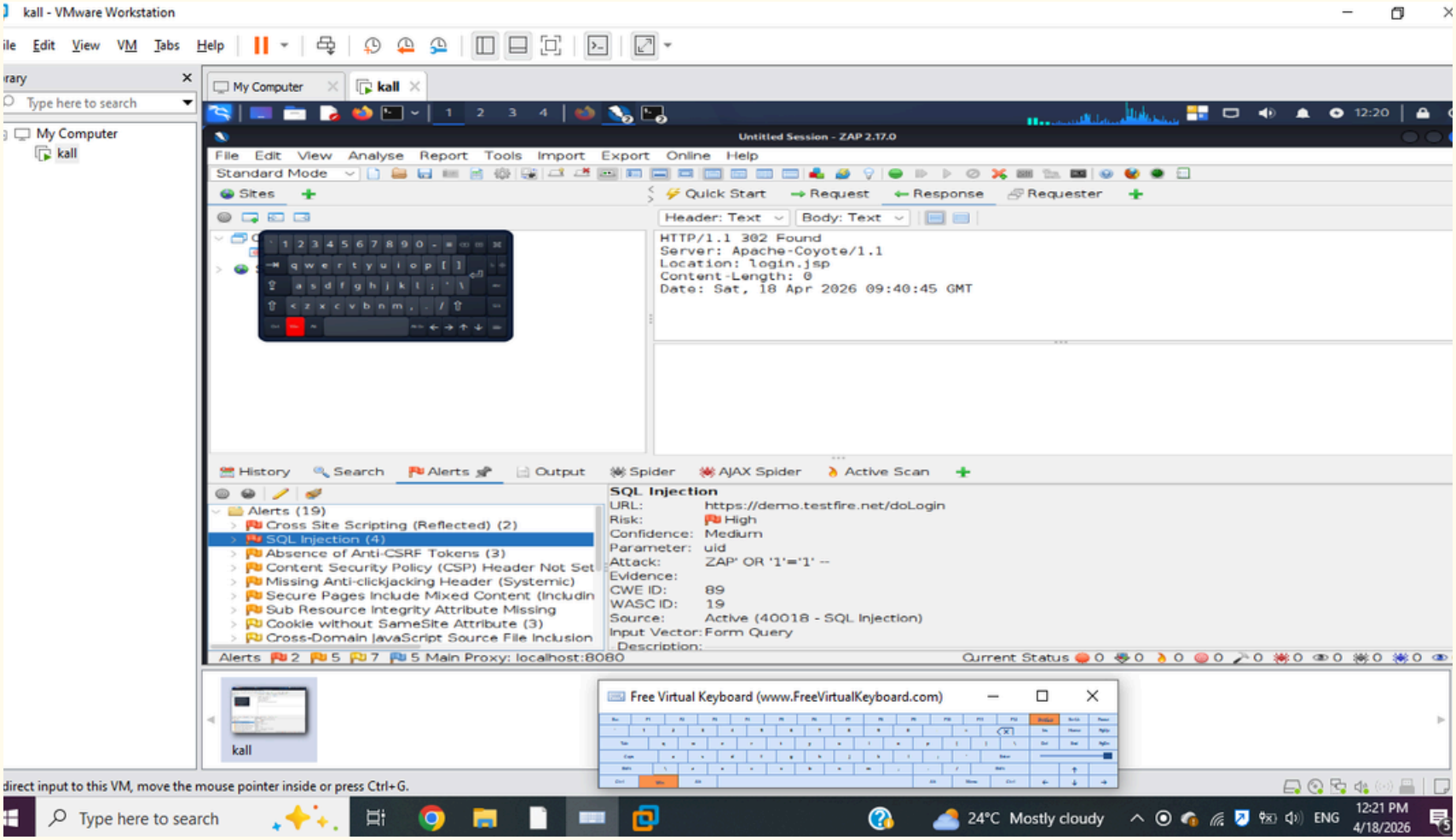
BrowserDev tools On

FINDINGS : EVIDENCE



Nmap findings on Kali linux using "nmap sP"

FINDINGS : EVIDENCE



OWASP ZP findings using automated scan

RECOMMENDATION

- SQL Injection:
  - Use prepared statements with parameterized queries
  - Input validation and sanitization
  - Limit database privileges

- Cross-Site Scripting (XSS):
- Validate and sanitize user input
  - Use Content Security Policy (CSP) headers
  - Escape output date

- Outdated JavaScript Library:
Update libraries to the latest versions

- Missing Security Headers:
Configure X-Frame-Options, X-XSS-Protection, and CSP headers

- Sensitive Data Exposure:
Store sensitive data securely (environment variables, secure vaults)

- Insecure Cookies:
Set Secure and HttpOnly flags

DISCLAIMER

This vulnerability assessment was conducted for educational purposes only, with the intention of improving the security of the tested site. The findings and recommendations are not intended to be used for malicious purposes or to cause harm to the site or its users. The tester is not responsible for any consequences arising from the use or misuse of this information.